Analyse de risques EBIOS RM

Plateforme cloud ERP/CRM d’une PME de formation numérique

Nathan, Camille, Chloé | TP2 EBIOS Risk Manager | octobre 2026

Contexte et périmètre

Objet de l'étude

La plateforme cloud qui héberge l'ERP et le CRM :

- hébergement IaaS, serveurs ERP et CRM, base de données
- annuaire et sauvegardes
- accès distant du prestataire d'infogérance
- postes de travail et messagerie

Méthode
EBIOS Risk Manager (ANSSI, v1.5), 5 ateliers, classeur officiel

Exclusions
Le LMS (déjà vu en MEHARI) et les événements accidentels

Limites
Cas fictif, sans audit sur place : cotations à dire d'experts, hypothèses tracées

Qui menace la PME, et pour quoi faire

SROV1	**Organisation criminelle** Rançon : chiffrer l'ERP et le CRM, voler les données	**Élevée**
SROV2	**Organisation criminelle** Détourner des paiements par faux RIB	**Élevée**
SROV3	**Concurrent** Récupérer le fichier clients et les tarifs	**Moyenne**
SROV4	**Salarié ou ex-salarié** Emporter ou altérer les données du CRM	**Moyenne**
SROV5	**Amateur ou hacktiviste** Rendre la plateforme indisponible par défi	**Moyenne**

Exclus

Activiste : aucune cause liée à l'activité

État : moyens énormes, mais aucun intérêt pour une PME

48 % des victimes de rançongiciel traitées par l'ANSSI en 2025 sont des TPE, PME ou ETI.

Ce qu'on protège et ce qu'on redoute

VM1

Gestion commerciale et relation client

Indisponibilité, altération ou fuite du CRM

Pire : G3

VM2

Fichier clients et apprenants

Divulgation massive de données personnelles (RGPD)

Pire : G4

VM3

Facturation et encaissement

Altération des montants et coordonnées bancaires

Pire : G4

VM4

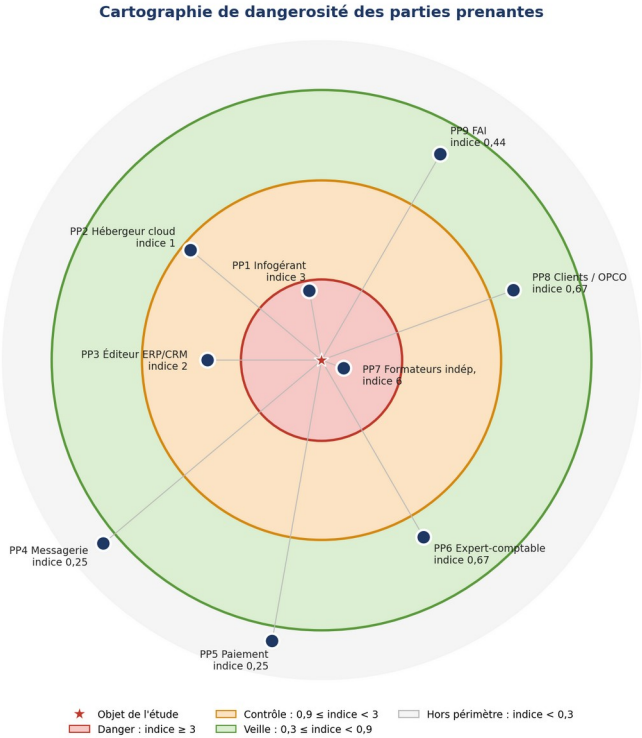
Planification des sessions

Planning indisponible ou faussé

Pire : G3

12 événements redoutés, dont 2 critiques (G4) : la fuite massive du fichier clients et le détournement de paiements.

Par où l'attaque peut passer



4 parties prenantes critiques sur 9

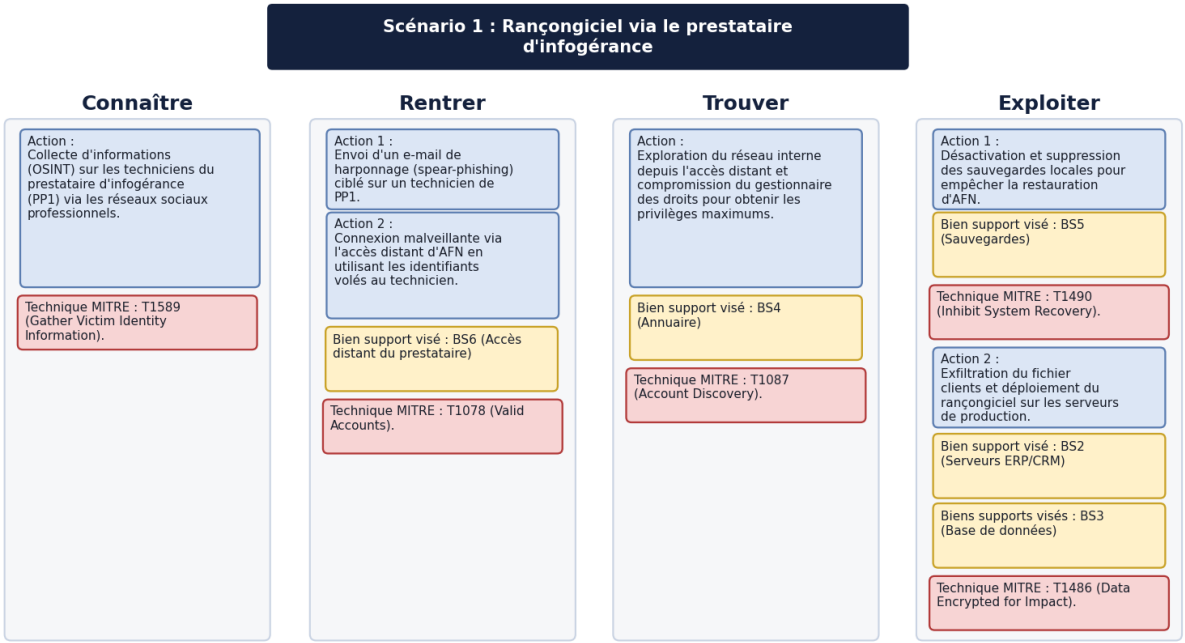
PP7 Formateurs indépendants	indice 6,0	**Danger**
PP1 Prestataire d'infogérance	indice 3,0	**Danger**
PP3 Éditeur ERP/CRM	indice 2,0	**Contrôle**
PP2 Hébergeur cloud	indice 1,0	**Contrôle**

Accès administrateur permanent pour l'infogérant, sécurité très faible chez les formateurs.

Cinq scénarios d'attaque

	Qui	Par où	Ce qui est touché	
SS1	**Organisation criminelle**	via l'infogérant (PP1)	ERP et CRM chiffrés, données volées	G4
SS2	**Organisation criminelle**	attaque directe par hameçonnage	RIB modifié, paiements détournés	G4
SS3	**Concurrent**	via un formateur indépendant (PP7)	Fichier clients récupéré	G3
SS4	**Ex-salarié**	compte non désactivé (annuaire géré par PP1)	Données du CRM emportées ou altérées	G3
SS5	**Amateur**	faille de l'éditeur (PP3) ou saturation chez l'hébergeur (PP2)	Plateforme et planning indisponibles	G3

Le rançongiciel, étape par étape



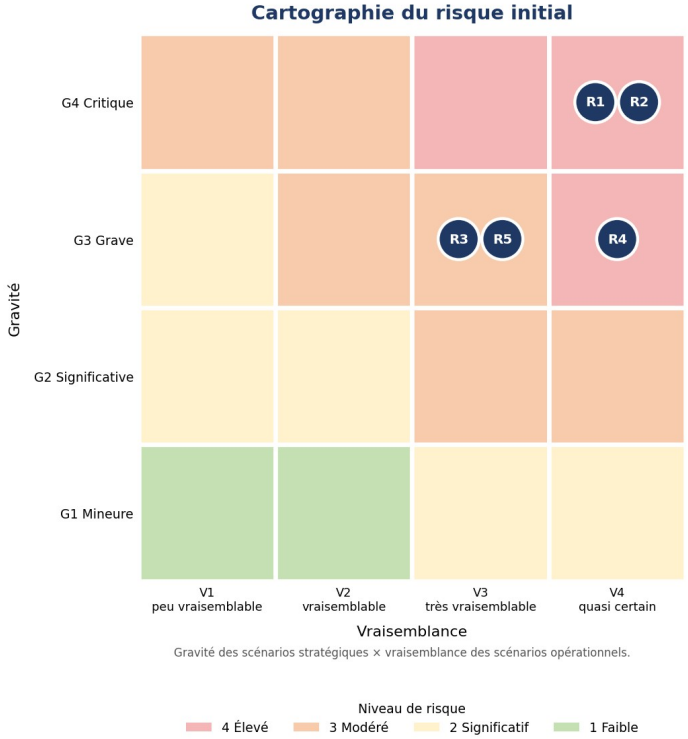
V4

quasi certain aujourd'hui

Aucun MFA sur l'accès de l'infogérant, aucun cloisonnement, sauvegardes atteignables

Techniques MITRE ATT&CK associées à chaque étape. Graphes de SO2 à SO4 dans le dossier.

Où en est la PME aujourd'hui



3 risques élevés

R1	Rançongiciel via l'infogérant	G4 × V4
R2	Fraude au faux RIB	G4 × V4
R4	Fuite par un ex-salarié	G3 × V4

R3 (concurrent via un formateur) et R5 (amateur) sont modérés.

Le plan : 14 mesures en 3 vagues

Vague 1 0 à 3 mois

- M9 Double authentification partout
- M10 Contre-appel avant tout changement de RIB
- M6 Sauvegardes déconnectées testées
- M3 Revue des accès prestataires
- M1 Responsabilités SSI claires
- M14 Droits des formateurs limités

Vague 2 3 à 6 mois

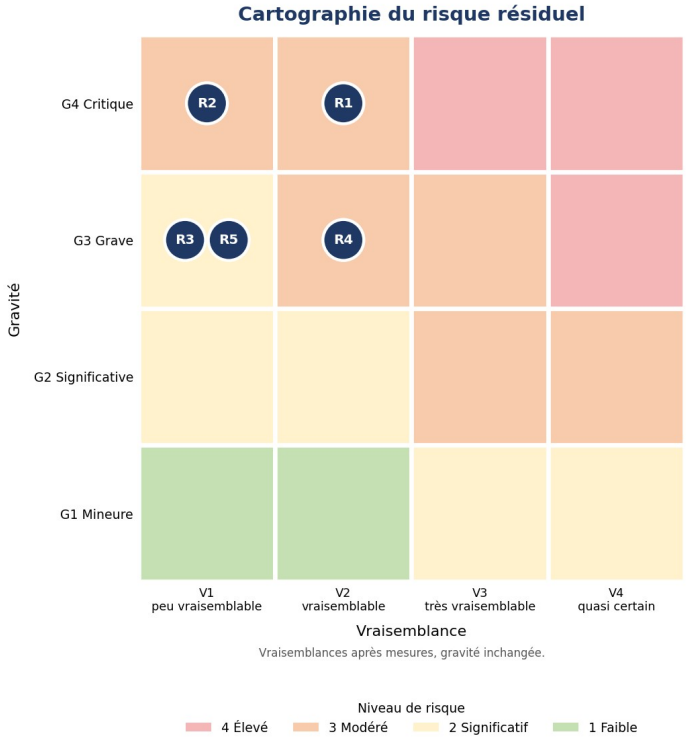
- M2 Avenant sécurité avec l'infogérant
- M11 Blocage des exports massifs et clés USB
- M4 Sensibilisation hameçonnage
- M8 Gestion de crise cyber
- M13 Supervision des accès

Vague 3 6 mois et plus

- M7 Mode dégradé sans ERP ni CRM
- M5 Clause incidents fournisseurs
- M12 Pare-feu applicatif et correctifs

M9 en tête : la double authentification bloque à elle seule l'entrée des deux risques les plus graves. Vague 1 : coût faible (configuration et procédures).

Après le plan, et ce qu'on attend de vous



Plus aucun risque élevé. R3 et R5 deviennent significatifs ; R1, R2 et R4 restent modérés car leurs conséquences restent graves.

1. Valider le plan en 3 vagues et désigner son pilote, avec un point chaque trimestre

2. Négocier un avenant de sécurité avec l'infogérant, sans lequel le plan ne s'applique pas

3. Accepter le risque restant sur R1, R2 et R4, ou aller plus loin avec une assurance cyber